

PoC

PoC - lachlan2k, GitHub.

- Published: date not stated
- Original: <<https://github.com/lachlan2k/React2Shell-CVE-2025-55182-original-poc>>
- Preserved from: <https://github.com/lachlan2k/React2Shell-CVE-2025-55182-original-poc> (git) on 2026-08-08
- Repository commit: `e7e2e38b1bda60def733913007464167fe68c557`
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This reference is a source-code repository. The archive preserves its documentation at an exact commit; the code itself stays in a private mirror and is never checked out, built or run.

- Repository: <<https://github.com/lachlan2k/React2Shell-CVE-2025-55182-original-poc>>
- Commit: `e7e2e38b1bda60def733913007464167fe68c557`
- Documents preserved: 1

README.md

Blob `2705a7f93bf7`, 1854 bytes, at commit `e7e2e38b1bda`.

Original PoCs for CVE-2025-55182

As public PoCs are circulating and [Google's Scanner](#) uses a variation of my original submitted PoC, it's finally a responsible time to share my original PoCs for [React2Shell](#).

This repository contains 3 PoCs:

- `00-very-first-rce-poc` - the very first PoC I managed to develop for RCE. Only directly works on dev builds of Next.js sites that use Webpack.
- `01-submitted-poc.js` (the main one) - the exact PoC I submitted to Meta, far simpler and effective
- `02-meow-rce-poc` - the PoC hashed and [posted as proof by Sylvie](#) on November 29th, shortly before initial disclosure to Meta

TL;DR

Many other people have explained their PoCs, but here's my very brief explainer:

- `$@x` gives you access to a `Chunk`
- We plant its `then` on our own object
- The JS runtime automatically unravels nested promises (really, anything with a `.then` function)
- We now re-enter the parser, but with control of a malicious fake `Chunk` object
- Planting things on `_response` lets us access a *lot* of gadgets when this happens
- (insert several options here)
- RCE

Some Differences in PoC

You might notice my PoC has a funny thing going on in `then`. This was a nice primitive I was using for 'chaining' multiple chunks together, where `resolve` is passed to `Array.map` to let me "hop" to another chunk defined in `$0`.

The publicly recreated PoC circulating doesn't do this, as it's not necessary when just doing a single jump. It was nice to see that the re-created PoC did otherwise use the same `_formData` gadget that mine did - but the `00-` PoC is a wild ride, if you dare try to read it :)

Full Writeup

Soon.

Archived from <https://github.com/lachlan2k/React2Shell-CVE-2025-55182-original-poc>. Rendered offline from the local Markdown copy.